Practice Questions

Part A: Conceptual Multiple Choice

For each question, choose the best answer *and* be ready to explain in one or two sentences why the other options are wrong.

1. (Ch. 1) What makes OTP provably secure?
   A. The key is very long
   B. The ciphertext is uniformly distributed regardless of the plaintext
   C. The XOR operation is fast

2. (Ch. 2) In the library/program model, what can programs NOT do?
   A. Call library subroutines
   B. Read library variables directly
   C. See the output of function calls

3. (Ch. 2) When are two libraries considered interchangeable?
   A. When they have the same source code
   B. When they run in the same amount of time
   C. When they have the same interface and produce indistinguishable outputs

4. (Ch. 4) What does it mean for a function to be negligible?
   A. It runs in polynomial time
   B. It approaches zero faster than any polynomial fraction
   C. It can be computed efficiently

5. (Ch. 4) What is the general implication of the birthday paradox for cryptography?
   A. We need small key spaces
   B. Finding collisions happens with roughly $\sqrt{N}$ samples in a space of size N
   C. Birthday attacks are impossible to prevent

6. (Ch. 4) What is the key idea behind the "bad event" proof technique?
   A. Bad events always happen
   B. Libraries differ only when a rare bad event occurs
   C. We can prevent all bad events

7. (Ch. 6) What is the primary difference between a PRG and a PRF?
   A. PRFs provide selective access to pseudorandom values for any input
   B. PRGs are more secure than PRFs
   C. PRFs are faster to compute than PRGs

8. (Ch. 7) What makes Feistel ciphers always permutations?
   A. They use strong encryption algorithms
   B. Each round is invertible without inverting the round function
   C. They require reversible round functions

9. (Ch. 7) What attack can break a 2-round Feistel cipher?
    A. Observing that the XOR of the outputs' left halves equals the XOR of the inputs' left halves when inputs share the same right half
    B. Birthday attack on the round function
    C. Exhaustive key search

10. (Ch. 6, 8) What is the "Golden Rule of PRFs"?
    A. PRFs should use large key sizes
    B. Security depends on ensuring distinct inputs to the PRF
    C. PRFs must be implemented in hardware

11. (Ch. 8) What information is allowed to leak even in a CPA-secure encryption scheme?
    A. The encryption key
    B. The first byte of the plaintext
    C. The length of the message

12. (Ch. 9) What property makes CTR mode vulnerable to chosen-ciphertext attacks?
    A. It uses weak encryption
    B. It is malleable – bit flips in the ciphertext cause predictable changes in the plaintext
    C. It requires too much memory

13. (Ch. 9) Why is Encrypt-and-MAC not even CPA-secure?
    A. The encryption is too weak
    B. The MAC key is exposed
    C. The MAC is computed on the plaintext, leaking equality information

Part B: Short Answer

14. (Ch. 1) A startup claims to have developed a "quantum-resistant ultra-secure messaging system" based on the one-time pad. They provide the following details:

    - The system uses a hardware random number generator to produce one-time pads.
    - During account registration, each user receives a 1TB USB drive containing pre-generated pad data.
    - When sending a message, the app encrypts it with a portion of the pad, marks that portion as used, and sends the ciphertext.
    - When the user has used 80% of their pad, the app automatically requests a new USB drive.

    Provide a detailed critique of this system:

    (a) Identify at least three practical problems with this implementation.

    (b) Explain how each problem compromises security or usability.

    (c) Suggest improvements to address each issue while maintaining the theoretical security of OTP.

15. (Ch. 1–2) Consider the following game between a challenger and an adversary $\mathcal{A}$:
    (a) The adversary selects two messages M_0 and M_1 of the same length.
    (b) The challenger selects a uniform random bit $b \twoheadleftarrow \{0,1\}$ and a uniform random key $K \twoheadleftarrow \{0,1\}^n$.
    (c) The challenger computes $C = K \oplus M_b$ and gives C to the adversary.
    (d) The adversary outputs a bit b' as its guess for b.

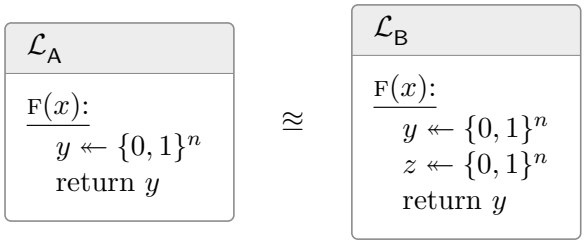
    Prove that for any adversary $\mathcal{A}$, the probability that $b' = b$ is exactly $1/2$. Explain what this result tells us about the security of the one-time pad.

16. (Ch. 1–2) A software company is implementing a secure communication protocol for their instant messaging application. They propose the following scheme:

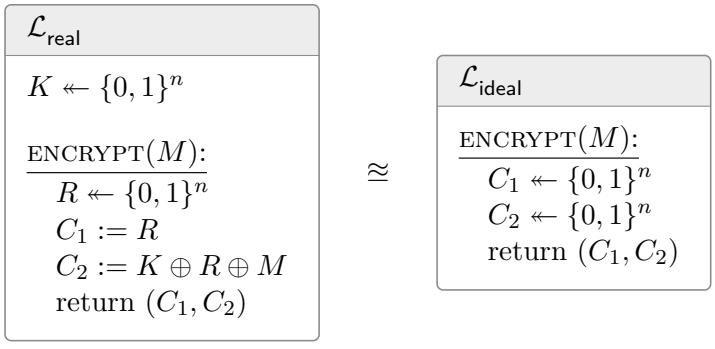
    - Each user generates a random 128-bit key K during account creation.
    - To send a message M, the sender computes $C = K \oplus M$ and transmits C.
    - When two users want to communicate, they first exchange their keys through a "top secret channel" established by the company's server.
    - The company claims their protocol is "as secure as the one-time pad" because they use the XOR operation.

    (a) Using the provable security framework discussed in class, analyze whether this scheme provides the confidentiality properties claimed by the company.
    (b) Identify at least three major security vulnerabilities in the described approach.
    (c) The company is considering having users generate new keys daily instead of just once. Explain whether this modification would address the vulnerabilities you identified.

17. (Ch. 2) State whether the following libraries are indistinguishable and briefly justify your answer:



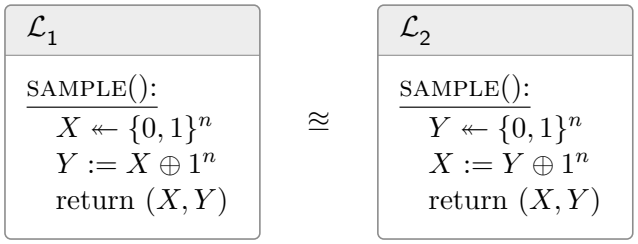
18. (Ch. 2) Consider a protocol where Alice wants to send encrypted messages to Bob. They use the following scheme:



    (a) The above libraries are not actually indistinguishable! Construct a distinguisher.

(b) Propose a minimal modification to make the above "real" library secure and explain why your modification works.

19. (Ch. 2, 4) Consider the following two libraries:



Use the hybrid proof technique to show these libraries are indistinguishable. Clearly describe each intermediate hybrid library.

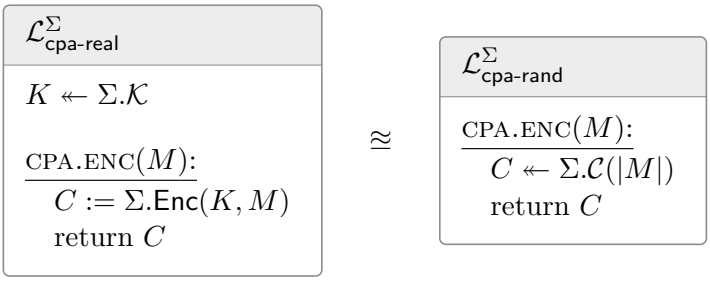
20. (Ch. 4) Explain why computational security is important in practice despite the existence of information-theoretic security. Discuss the limitations of both approaches.

21. (Ch. 4) The "birthday paradox" is crucial for understanding many cryptographic attacks. If a hash function produces outputs of length n bits:
    (a) Approximately how many random inputs would you need to hash before finding a collision with 50% probability?
    (b) How many bits of output would a hash function need to be reasonably secure against birthday attacks for the next decade?

22. (Ch. 5) Explain the limitations of the one-time pad for practical encryption and why pseudorandom generators (PRGs) are needed in modern cryptographic systems.

23. (Ch. 6–7) Compare and contrast PRFs and PRPs:
    (a) Explain the key differences in their definitions and properties.
    (b) Describe how PRPs can be "downgraded" to PRFs, but not necessarily vice versa.
    (c) Explain why collisions are inevitable for PRFs but not for PRPs.

24. (Ch. 8) Consider the CPA security definition:



    (a) Explain why deterministic encryption schemes always fail CPA security.
    (b) Construct a simple distinguisher program that can break the CPA security of any deterministic encryption scheme.
    (c) Analyze what practical security vulnerabilities exist in systems that use non-CPA-secure encryption.

25. (Ch. 9) Format oracle attacks:

(a) Explain how the null-oracle attack works against CTR mode encryption and why it's devastating despite CTR mode being CPA-secure.

(b) Describe a real-world scenario where a format oracle might be inadvertently exposed in a cryptographic system.

(c) Calculate the approximate number of oracle queries needed to recover a 1KB file using the null-oracle attack, and explain why this is practical for an attacker.

26. (Ch. 9) Explain a scenario where replay attacks could succeed even against a system using authenticated encryption, and how associated data (AD) addresses this vulnerability.

Part C: Recommended Textbook Exercises

27. Exercise 1.15 (Ch. 1). A one-time pad variant where encryption is multiplication mod n over $\{1, \ldots, n-1\}$: for which values of n is the ciphertext uniformly distributed, and why?

28. Exercise 2.13 (Ch. 2). A scheme with keys and plaintexts in $\{1, \ldots, 9\}$ that encrypts by multiplying key and plaintext mod 10: prove that it does not have one-time secrecy.

29. Exercise 2.14 (Ch. 2). Show that an encryption scheme with fewer keys than plaintexts cannot have one-time secrecy.

30. Exercise 5.21 (Ch. 5). Decide whether the given feedback-style construction built from a length-doubling PRG is a secure PRG; give a proof or an attack.

31. Exercise 6.9 (Ch. 6). Show that $H(K, X) = F(K, X) \oplus F(K, 0^n)$ is not a secure PRF, even if F is.

32. Exercise 7.4 (Ch. 7). Show that a Feistel cipher whose round function is $F(K_i, X) = K_i \oplus X$ is not a secure PRP, for any number of rounds.

33. Exercise 8.11 (Ch. 8). Show that a correct encryption scheme with $|\mathcal{M}| = |\mathcal{C}|$ cannot be CPA-secure.

34. Exercise 9.21 (Ch. 9). Encrypting the same plaintext twice and checking at decryption that both halves agree: show that the result is not CCA-secure, even when the underlying scheme is.